



Compte-rendu N°2

Sécuriser un système d'information

SAE4.Cyber.01

IUT DE BLOIS

Département Réseaux & Télécommunications

Réalisé par : Parre Raphaël, Frain Martin

Enseignant : M. Ludovic Fontaine

Année universitaire: 2025-2026

Table des matières

Compte-rendu N°2	1
Liste des outils de pentesting	1
netdiscover	1
nmap	1
gobuster & nikto	1
smtp-user-enum	1
hydra (Credential Stuffing)	2
yersinia (VLAN Hopping - DTP)	2
yersinia (STP Manipulation)	2
hashcat	2
Vérification manuelle des ACLs	2
Vol de clés privées SSH	3

Liste des outils de pentesting

L'objectif de cette phase de pentesting est d'évaluer la robustesse de l'infrastructure réseau de l'entreprise adverse face à différentes menaces réalistes. L'audit vise à identifier les vulnérabilités potentielles affectant la confidentialité, l'intégrité et la disponibilité du système d'information.

Pour évaluer la sécurité de l'entreprise adverse à différents niveaux, notre méthodologie se base autour de trois scénarios d'attaque, simulant des niveaux de privilèges et des points d'accès de plus en plus dangereux.

Phase 1 : Attaquant Extérieur - T=9h

Simulation d'un pirate accédant uniquement au réseau public d'interconnexion (Test-Net 203.0.113.0/24), sans aucune connaissance de l'architecture interne.

netdiscover

Cible : Le sous-réseau public simulé 203.0.113.0/24 (Test-Net).

Objectif : Découvrir l'adresse IP publique du WAN du routeur de l'entreprise adverse

nmap

Cible : L'adresse IP publique du routeur adverse.

Objectif : Énumérer les ports NAT (redirigés) vers la DMZ (ex: 80, 443, 25, 143) pour vérifier si le pare-feu/ACL externe filtre correctement.

gobuster & nikto

Cible : Le Serveur Web Public situé dans la DMZ (via l'adresse IP publique).

Objectif : Découverte de répertoires cachés (Gobuster) et scan de vulnérabilités/mauvaises configurations du service web (Nikto).

smtp-user-enum

Cible : Le Serveur Mail situé dans la DMZ (via le port 25 public).

Objectif : Utiliser les commandes SMTP pour valider l'existence d'adresses mails d'employés si l'on veut effectuer une attaque d'ingénierie sociale (phishing) ou pour le bruteforce.

Phase 2 : Employé Malveillant (T=10h)

Lors de cette attaque nous devons simuler une menace interne (employé malveillant). L'attaquant dispose d'un accès physique au réseau local (LAN, VLAN Data) via une

machine (Kali Linux). Etant donné que nous sommes déjà dans le LAN, il n'y aura pas de phase de reconnaissance. Nous passerons directement à l'exploitation.

hydra (Credential Stuffing)

Cible : Les accès SSH des équipements réseaux (Routeurs, Switchs, Serveur Web, Mail, DNS).

Objectif : Prouver que les mots de passe utilisateurs compromis peuvent engendrer une élévation de privilège si les employés réutilisent leurs mots de passe sur des services d'administration ou que les mots de passe ne soient pas sécurisés.

yersinia (VLAN Hopping - DTP)

Cible : L'interface du Switch d'accès sur lequel la machine Kali est branchée physiquement.

Objectif : Exploiter une mauvaise configuration du port (mode dynamic auto) pour monter un lien Trunk et sortir du VLAN Data vers les VLANs sensibles (Admin, DMZ).

yersinia (STP Manipulation)

Cible : Le protocole Spanning Tree du Switch local.

Objectif : Forcer une priorité à 0 pour devenir le pont racine, ce qui va rediriger le trafic réseau vers le PC de l'attaquant pour l'intercepter (Man-in-the-Middle) ou créer une panne (Déni de service).

Phase 3 : Admin/Root Malveillant (T=11h)

Pour finir, on simule un utilisateur interne possédant des droits d'administration partiels. Nous aurons les accès d'un admin, donc par définition nous avons un accès complet au réseau de l'entreprise. Nous allons tester l'accès au mot de passe SSH des Switchs et Routeurs ainsi que l'isolation définies par les ACL.

hashcat

Cible : Le fichier de configuration (running-config) extrait du Routeur Cisco compromis.

Objectif : Casser les mots de passe (enable secret) hachés en MD5/SHA pour les réutiliser sur d'autres équipements réseaux et ainsi tester encore une fois la politique de mot de passe.

Vérification manuelle des ACLs

Cible : Le Routeur interne (Routeur LAN).

Objectif : Vérifier si les ACL sont bien configurées. Même si l'admin malveillant a accès au VLAN Admin, des ACLs strictes doivent l'empêcher d'accéder aux données sensibles de l'Intranet si ce n'est pas nécessaire.

Vol de clés privées SSH

Cible : Les répertoires cachés (ex: /root/.ssh/id_rsa) du serveur Windows compromis (ex: Serveur Web).

Objectif : Utiliser la relation de confiance entre les serveurs pour aller (via le terminal/CMD) vers un autre serveur (ex: Serveur Mail) sans connaître le mot de passe.